

Clase 025 — Ética, legalidad, alcance y divulgación responsable

Parte: **0 — Fundamentos y prerequisites** · Fuente: *EC-Council Code of Ethics / ISO/IEC 29147 y 30111*

 Duración estimada: **100 min** · Nivel: **Fundamentos**

Objetivo

Interiorizar el marco legal y ético que separa a un profesional de seguridad de un delincuente. Al terminar sabrás qué es la autorización, cómo se define y respeta el alcance de un compromiso, qué dicen las leyes relevantes y cómo divulgar vulnerabilidades de forma responsable. Esta clase es la que legitima todo lo demás del programa.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** por qué la autorización explícita es la línea que no se cruza.
2. **Definir** el alcance (scope) de un compromiso y respetarlo.
3. **Identificar** las leyes relevantes de delitos informáticos.
4. **Aplicar** un proceso de divulgación responsable (CVD).
5. **Redactar** los elementos clave de un acuerdo de pentesting (RoE).

Temas

#	Tema	Por qué importa
1	Autorización	La frontera entre legal e ilegal
2	Alcance (scope)	Qué se puede tocar y qué no
3	Reglas de compromiso (RoE)	Contrato del pentest
4	Marco legal	Leyes de delitos informáticos
5	Tipos de hacker	White/grey/black hat
6	Divulgación responsable	CVD y bug bounties
7	Manejo de datos	Confidencialidad de hallazgos
8	Ética profesional	Códigos y certificaciones

Definiciones y características

- **Autorización:** permiso explícito, por escrito, del propietario del sistema para probarlo. Clave: sin ella, cualquier prueba es un delito, aunque la intención sea buena.

- **Alcance (scope):** conjunto de activos, rangos y técnicas permitidas. Clave: salir del alcance convierte un test autorizado en ilegal.
- **Reglas de compromiso (RoE):** documento que fija alcance, ventanas de tiempo, contactos, técnicas prohibidas y manejo de datos. Clave: protege a ambas partes.
- **Divulgación coordinada (CVD):** proceso de reportar una vulnerabilidad al fabricante y dar plazo antes de publicarla. Clave: equilibra transparencia y riesgo.
- **Bug bounty:** programa que autoriza y recompensa el reporte de fallos dentro de reglas publicadas. Clave: autorización previa acotada.
- **White/grey/black hat:** hacker ético, ambiguo o malicioso. Clave: la diferencia esencial es la autorización y la intención.

Herramientas y preparación

Esta clase es conceptual y documental. Familiarízate con: la ley de delitos informáticos de **tu país** (por ejemplo, en EE. UU. la CFAA; en la UE la Directiva 2013/40/UE; consulta la de tu jurisdicción), los estándares **ISO/IEC 29147** (divulgación) y **30111** (gestión), plantillas de RoE y programas de bug bounty (HackerOne, Bugcrowd) para ver reglas reales.

Laboratorio guiado (ejercicio aplicado)

1. **Investiga tu jurisdicción.** Localiza la ley de delitos informáticos aplicable donde vives y anota qué conductas tipifica (acceso no autorizado, interceptación, daños).
2. **Analiza un caso.** Toma un escenario ("encontré una web con una vulnerabilidad evidente y la 'probé' sin permiso") y determina si es legal, por qué, y qué debió hacerse.
3. **Define un alcance.** Redacta el scope de un pentest ficticio: rangos IP incluidos y **excluidos**, aplicaciones, técnicas prohibidas (p. ej. DoS, ingeniería social al personal), ventana horaria.
4. **Redacta RoE mínimas.** Escribe las reglas de compromiso: contactos de emergencia, qué hacer si se encuentra un dato sensible real, manejo y destrucción de la información.
5. **Simula una divulgación responsable.** Redacta un informe de vulnerabilidad para un fabricante siguiendo CVD: descripción, impacto, pasos de reproducción, y una propuesta de plazo de publicación.
6. **Revisa un programa de bug bounty real** y extrae qué está en alcance, qué está fuera, y las reglas de "safe harbor".

Ejercicios

1. Explica por qué "tenía buena intención" no es defensa legal ante un acceso no autorizado.
2. Enumera 6 elementos que no pueden faltar en unas RoE de pentest.
3. Da tres ejemplos de acciones que, aun con autorización general, deberían estar explícitamente excluidas del alcance.
4. Describe el proceso de divulgación coordinada paso a paso, incluyendo qué hacer si el fabricante no responde.
5. Diferencia hacking ético, grey hat y black hat con un ejemplo de cada uno.
6. Investiga qué es una cláusula de "safe harbor" en un bug bounty y qué protege.

Reto verificable

Elabora un paquete de autorización completo para un compromiso ficticio: (1) un documento de alcance con activos incluidos y excluidos, (2) reglas de compromiso con contactos y técnicas prohibidas, (3) una cláusula de confidencialidad y manejo de datos, y (4) una plantilla de informe de divulgación responsable. Debe ser suficiente para que un tercero entienda qué está y qué no está autorizado.

Criterio de aceptación: un revisor puede determinar sin ambigüedad, a partir de tus documentos, si una acción concreta (p. ej. escanear una IP dada o lanzar un DoS) está autorizada o no. El paquete incluye qué hacer ante el hallazgo de datos sensibles reales y respeta la ley de tu jurisdicción.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Es solo un escaneo, no hace daño"	Escanear sin permiso ya puede ser delito según la jurisdicción. Exige autorización siempre.
Autorización verbal o informal	Insuficiente y arriesgada. Debe ser explícita y por escrito, con alcance claro.
Salirse del alcance "porque encontré algo interesante"	Convierte un test legal en ilegal. Ante hallazgos fuera de scope, para y consulta.
Publicar un 0-day sin avisar al fabricante	Irresponsable y a veces ilegal. Sigue un proceso CVD con plazos.
Guardar datos reales del cliente tras el test	Riesgo legal y ético. Define destrucción y manejo en las RoE.

Preguntas frecuentes

? ¿Puedo practicar en cualquier web "para aprender"? No. Practica solo en tu laboratorio, en plataformas diseñadas para ello (HackTheBox, TryHackMe, VulnHub, CTFs) o en programas de bug bounty que te autoricen explícitamente dentro de sus reglas.

? ¿La autorización de un empleado basta? Debe provenir de quien tiene potestad sobre el sistema (propietario o responsable con autoridad). Verifica que quien firma puede autorizar legalmente el test.

? ¿Qué hago si encuentro una vulnerabilidad grave por casualidad? No la explotes ni la difundas. Sigue divulgación coordinada: contacta al responsable de forma privada, documenta con cuidado y da un plazo razonable antes de publicar.

? ¿Un bug bounty me protege legalmente? Solo dentro de su alcance y reglas ("safe harbor"). Salirte de ellas te deja sin protección. Lee siempre la política antes de probar.

Referencias

- ISO/IEC 29147 (divulgación de vulnerabilidades) — <https://www.iso.org/standard/72311.html>
- ISO/IEC 30111 (gestión de vulnerabilidades) — <https://www.iso.org/standard/69725.html>

- CISA Coordinated Vulnerability Disclosure — <https://www.cisa.gov/coordinated-vulnerability-disclosure-process>
- EC-Council Code of Ethics — <https://www.eccouncil.org/code-of-ethics/>

Siguiente clase

Clase 026 - Wireshark: captura y análisis de paquetes